

JAWABAN KUESIONER KEAMANAN

IntelliBase AI · Lampiran B Perjanjian Berlangganan (sebagai informasi) · Kondisi per 24 September 2026

Diberikan kepada :

Tanggal :

1. ARSITEKTUR DAN LOKASI DATA

Pertanyaan	Jawaban
Model layanan?	SaaS multi-tenant berbasis web. Tidak ada instalasi di server Pelanggan.
Di mana data disimpan?	Basis data PostgreSQL di Neon, infrastruktur AWS wilayah Singapura (ap-southeast-1). Aplikasi berjalan di Vercel.
Apakah data keluar dari Indonesia?	Ya. Basis data, hosting, dan penyedia AI (Google Gemini, Groq) berada di luar Indonesia. Hal ini diungkap dalam Kebijakan Privasi dan Perjanjian Pemrosesan Data.
Apakah berkas asli disimpan?	Tidak. Berkas diekstraksi menjadi teks; hanya teks, potongan, vektor, dan ringkasannya yang disimpan.
Siapa sub-prosesornya?	Google (Gemini API), Groq, Neon, Vercel, Resend, Midtrans, serta Slack bila integrasinya diaktifkan. Rincian ada di Perjanjian Pemrosesan Data Bagian 4.

2. ISOLASI TENANT, AKSES, DAN AUTENTIKASI

Pertanyaan	Jawaban
Bagaimana data kami dipisahkan dari pelanggan lain?	Row-level security (RLS) PostgreSQL. Setiap transaksi basis data menetapkan ID perusahaan, dan kebijakan RLS menolak baris milik perusahaan lain. Bila kode aplikasi keliru, hasilnya nol baris, bukan data pelanggan lain. Isolasi ini sudah diuji memakai peran basis data tanpa hak bypass.
Bagaimana kata sandi disimpan?	Sebagai hash, tidak pernah dalam bentuk teks biasa.
Apakah tersedia MFA/2FA?	Ya, autentikasi dua faktor (TOTP) tersedia untuk setiap pengguna. Saat ini belum dapat diwajibkan oleh admin untuk seluruh pengguna.
Apakah tersedia SSO?	Belum tersedia.
Model peran?	Admin (mengelola dokumen, pengguna, langganan) dan karyawan (bertanya). Hak akses diperiksa di sisi server pada setiap endpoint.
Bagaimana akun karyawan yang keluar ditangani?	Admin mengajukan permintaan ke hello@intellibaseai.com, dan akun dinonaktifkan oleh tim kami dalam 1 hari kerja. Fitur penonaktifan mandiri oleh admin sedang dikembangkan.

Siapa di pihak vendor yang bisa mengakses data kami?	Hanya pengelola teknis, untuk keperluan dukungan dan pemeliharaan, terikat kewajiban kerahasiaan.
Perlindungan terhadap serangan?	Pembatasan laju permintaan per IP, Content Security Policy, HSTS, pemindaian keamanan otomatis (OWASP ZAP) di pipeline CI, serta tinjauan keamanan dan uji penetrasi internal berkala.

3. ENKRIPSI DAN PENGGUNAAN DATA OLEH AI

Pertanyaan	Jawaban
Enkripsi saat transit?	Ya, HTTPS/TLS untuk semua lalu lintas, dengan HSTS.
Enkripsi saat disimpan?	Ya, enkripsi penyimpanan oleh penyedia basis data (Neon/AWS). Kunci API milik Pelanggan (BYOK) dienkripsi tambahan dengan AES-256-GCM. Kunci API publik disimpan sebagai hash.
Model AI apa yang dipakai?	Jawaban disusun oleh model Groq, dengan Google Gemini sebagai cadangan. Pengindeksan dokumen memakai model embedding Google Gemini.
Apakah data kami dipakai untuk melatih model AI?	Groq menyatakan tidak memakai data API untuk pelatihan. Untuk Gemini, lihat pilihan yang dicentang pada Perjanjian Pemrosesan Data Bagian 4 ayat 1: akun Gemini berbayar dari Penyedia, atau kunci API milik Pelanggan sendiri (BYOK).
Apakah jawaban AI bisa salah?	Bisa. Setiap jawaban disertai kutipan dokumen sumber agar dapat diverifikasi. Bila informasi tidak ditemukan di dokumen, sistem menyatakan tidak menemukannya alih-alih menebak.
Apakah AI menjawab dari pengetahuan umum?	Tidak. Jawaban dibatasi pada potongan dokumen Pelanggan yang relevan (retrieval-augmented generation).

4. PEMANTAUAN, INSIDEN, CADANGAN, DAN KEBERLANGSUNGAN

Pertanyaan	Jawaban
Bagaimana error dan gangguan terdeteksi?	Error sisi server dicatat di log dan dikirim sebagai notifikasi email otomatis ke pengelola.
Berapa lama log disimpan?	Maksimal 90 hari di penyedia infrastruktur.
Prosedur insiden kebocoran data?	Pelanggan diberi tahu paling lambat 48 jam setelah insiden diketahui, dengan rincian data terdampak dan langkah penanganan (Perjanjian Pemrosesan Data Bagian 5).
Cadangan data?	Cadangan otomatis dan pemulihan ke titik waktu tertentu (point-in-time restore) oleh penyedia basis data Neon.
Apakah ada rencana pemulihan bencana (DRP) tertulis?	Belum ada DRP tertulis yang teruji. Pemulihan mengandalkan cadangan Neon dan deploy ulang aplikasi dari repositori.

Bagaimana bila vendor berhenti beroperasi?	Pelanggan diberi tahu minimal 30 hari sebelumnya dan dapat meminta ekspor riwayat chat. Dokumen asli tetap berada pada Pelanggan.
Target ketersediaan?	99% per bulan sebagai upaya terbaik; belum ada SLA dengan kompensasi.

5. HAL YANG BELUM DIMILIKI

Kami menyampaikan bagian ini secara terbuka agar Pelanggan dapat menilai risikonya sejak awal.

Pertanyaan	Jawaban
Sertifikasi ISO 27001 / SOC 2?	Belum ada.
Uji penetrasi oleh pihak ketiga independen?	Belum ada. Uji penetrasi dan tinjauan keamanan selama ini dilakukan secara internal.
Server di Indonesia?	Belum tersedia.
Log audit tindakan admin?	Belum ada. Yang tersedia adalah riwayat pertanyaan dan jawaban per pengguna.
SSO dan kewajiban 2FA untuk semua pengguna?	Belum tersedia.
Fitur mandiri ekspor/hapus data untuk subjek data?	Belum ada; ditangani manual melalui hello@intellibaseai.com dalam 30 hari.

6. LEGALITAS VENDOR

Bentuk usaha :

NIB :

NPWP :

Status PKP : ☐ PKP ☐ Non-PKP

Tanda daftar PSE (Komdigi) :